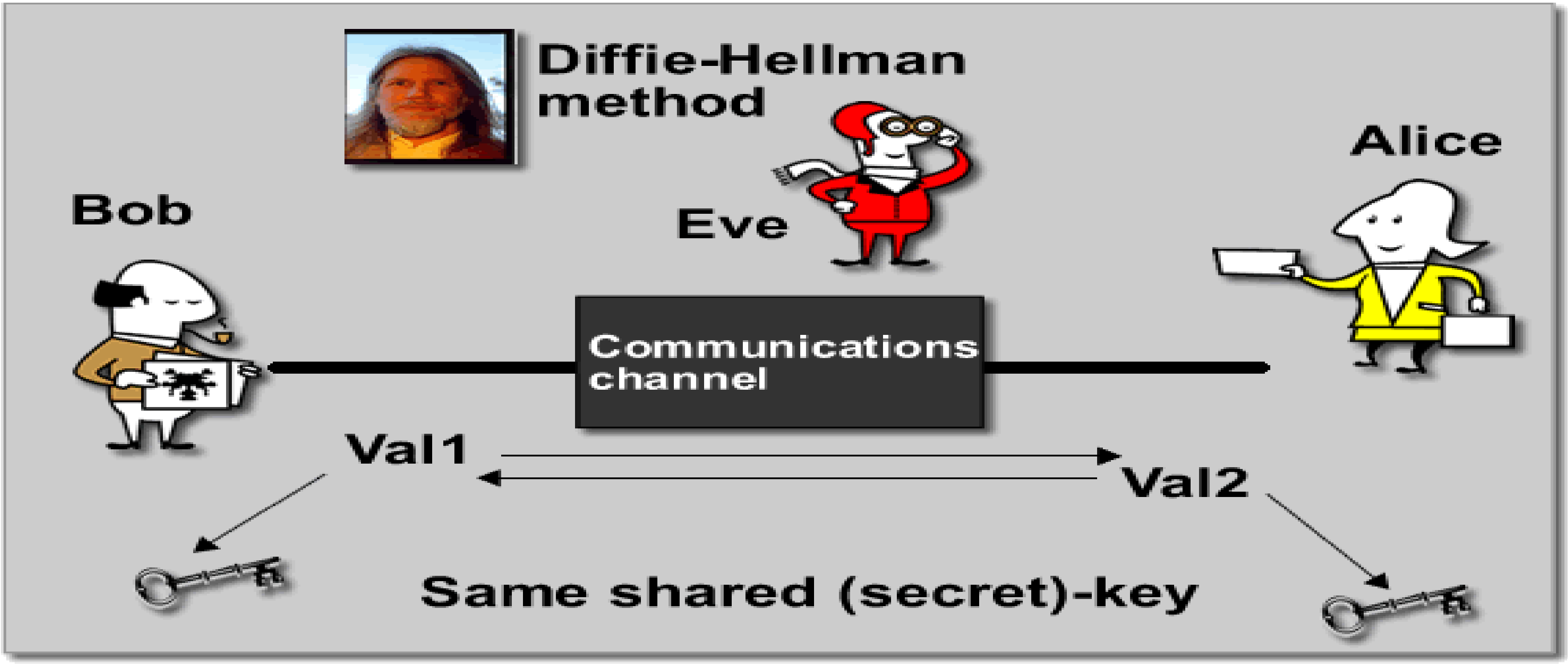
Cryptography and Network Security

Module 5 HMAC SHA



EHA: Easy Hash Algorithm

- Break m into n-bit blocks, append zeros to get a multiple of *n*.
- There are L of them, where L =|m|/n

$$m = \begin{bmatrix} m_1 \\ m_2 \\ \ldots \\ m_l \end{bmatrix} = \begin{bmatrix} m_{11} & m_{12} & \cdots & m_{1n} \\ m_{21} & m_{22} & \cdots & m_{2n} \\ \vdots & \vdots & \ddots & \vdots \\ m_{l1} & m_{l2} & \cdots & m_{ln} \end{bmatrix}$$

$$\begin{matrix} \oplus & \oplus & \oplus & \oplus \\ \Downarrow & \Downarrow & \Downarrow & \Downarrow \end{matrix}$$

$$\begin{bmatrix} c_1 & c_2 & \ldots & c_n \end{bmatrix} = h(m)$$

- Fast! But not very secure.
- Doing a left shift on the rows helps a little:
  - Define as left-shifting m by y bits
  - Then

$$m \hookleftarrow y$$

$$m_i' = m_i \hookleftarrow y$$

$$\begin{bmatrix} m_{11} & m_{12} & \ldots & m_{1n} \\ m_{22} & m_{23} & \ldots & m_{21} \\ \vdots & \vdots & \ddots & \vdots \\ m_{ll} & m_{l,l+1} & \cdots & m_{l,l-1} \end{bmatrix}$$

EHA: Easy Hash Algorithm

3 properties:

1. Fast to compute
2. One-way: given y = h(m), can't find any m' satisfying h(m') = y easily.
3. Strongly collision-free: Can't find m1 != m2 such that h(m1)=h(m2)

$$m = \begin{bmatrix} m_1 \\ m_2 \\ \dots \\ m_l \end{bmatrix} = \begin{bmatrix} m_{11} & m_{12} & \cdots & m_{1n} \\ m_{21} & m_{22} & \cdots & m_{2n} \\ \vdots & \vdots & \ddots & \vdots \\ m_{l1} & m_{l2} & \cdots & m_{\ln} \end{bmatrix}$$

$$\begin{matrix} \oplus & \oplus & \oplus & \oplus \\ \Downarrow & \Downarrow & \Downarrow & \Downarrow \end{matrix}$$

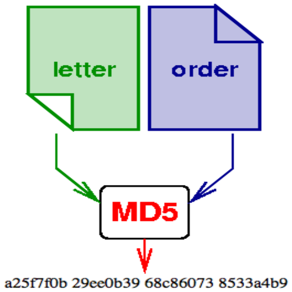
$$\begin{bmatrix} c_1 & c_2 & \dots & c_n \end{bmatrix} = h(m)$$

Exercise:

1. Show that the basic (unrotated) version doesn't satisfy properties 2 and 3.
2. Show that the rotated version doesn't satisfy properties 2 and 3 either.

MD5-Introduction

- MD5 algorithm was developed by Professor Ronald L. Rivest in 1991. According to RFC 1321, “MD5 message-digest algorithm takes as input a message of arbitrary length and produces as output a 128-bit "fingerprint" or "message digest" of the input …The MD5 algorithm is intended for digital signature applications, where a large file must be "compressed" in a secure manner before being encrypted with a private (secret) key under a public-key cryptosystem such as RSA.”



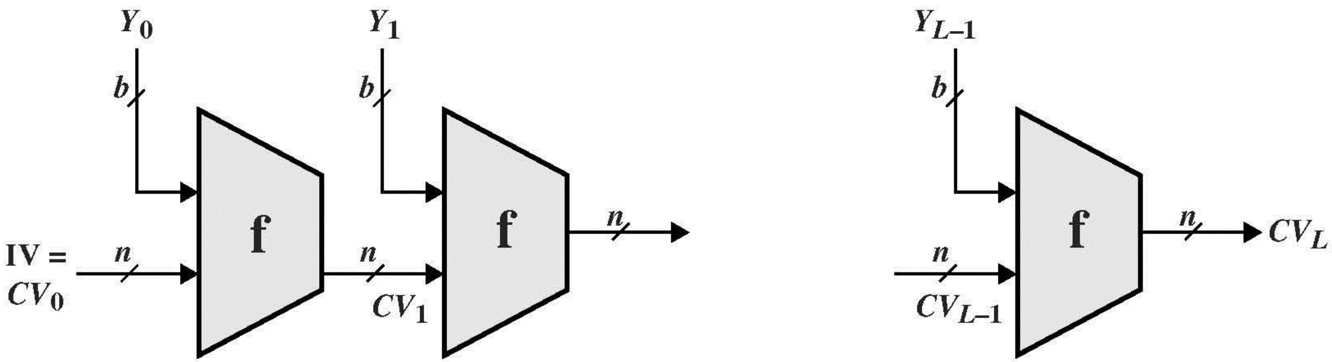
Hash Algorithms

- see similarities in the evolution of hash functions & block ciphers
  - increasing power of brute-force attacks
  - leading to evolution in algorithms
  - from DES to AES in block ciphers
  - from MD4 & MD5 to SHA-1 & RIPEMD-160 in hash algorithms
- likewise tend to use common iterative structure as do block ciphers

Hash Functions

- have a number of iterated hash functions
  - $CV_i = f[CV_{i-1}, M_i]; H(M)=CV_N$
  - typically focus on collisions in function f
  - like block ciphers is often composed of rounds

Hash Functions…



IV	=	Initial value
CV	=	chaining variable
Y_i	=	*i*th input block
f	=	compression algorithm
L	=	number of input blocks
n	=	length of hash code
b	=	length of input block

What is MD5 ?

- MD stands for message digest.
- MD5 is an algorithm which:
  - takes an input of any length
  - outputs a message digest of a fixed length (128-bit, 32 characters)
- Hash made up from only hexadecimal characters
- MD5 uses the same algorithm every time. Hence it will always generate the same message digest for the same string (data).

MD5 (Sample Outputs)

MD5 hashes have the advantage of generating completely different looking hashes from seemingly similar inputs. For example:

- The MD5 hash of bleh is

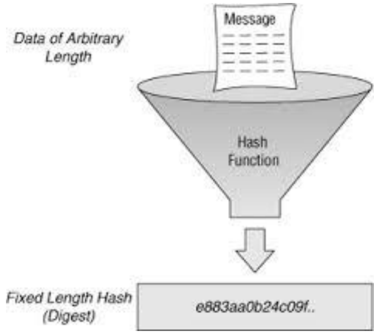
  4eb20288afaed97e82bde371260db8d8

- The MD5 hash of Bleh is

  dcc9f5ac2af04cedb008c04d5f9636b5

- The MD5 hash of Blehlo is

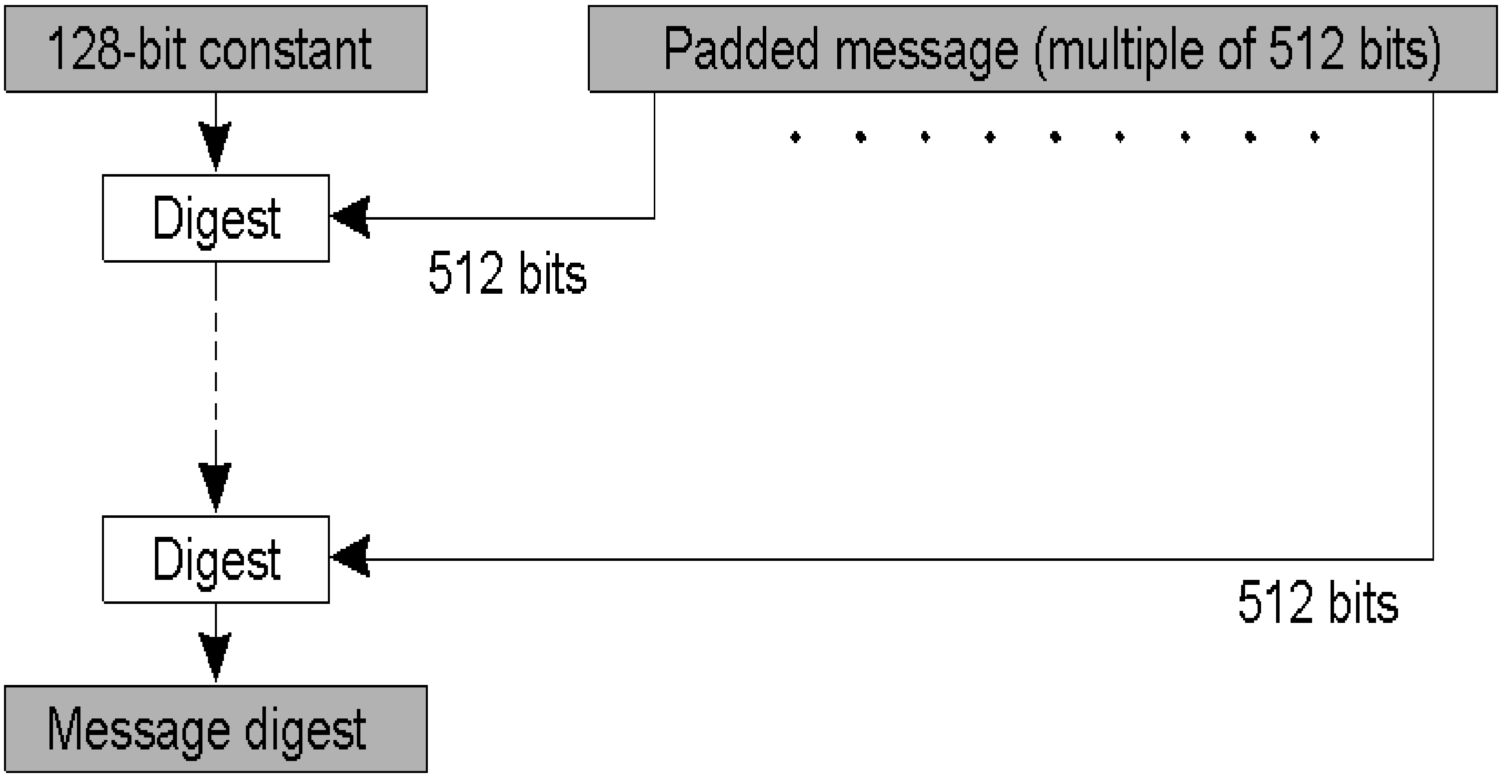
  7ed84db56d34b98757f884bf864b6448



Decoding an MD5 Hash

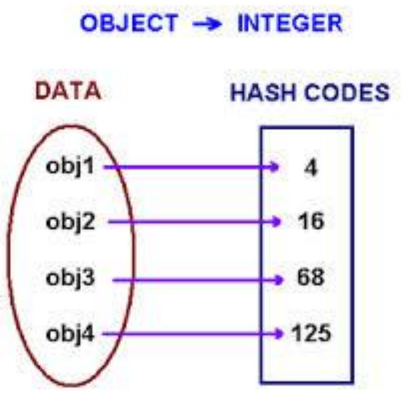
- A one way hash means that the message digest which is outputted by the MD5 algorithm is irreversible
- There's no known way of getting from the MD5 hash to the originally inputted string
- Only known way of getting the original string is by brute force cracking

MD5 Algorithm Structure

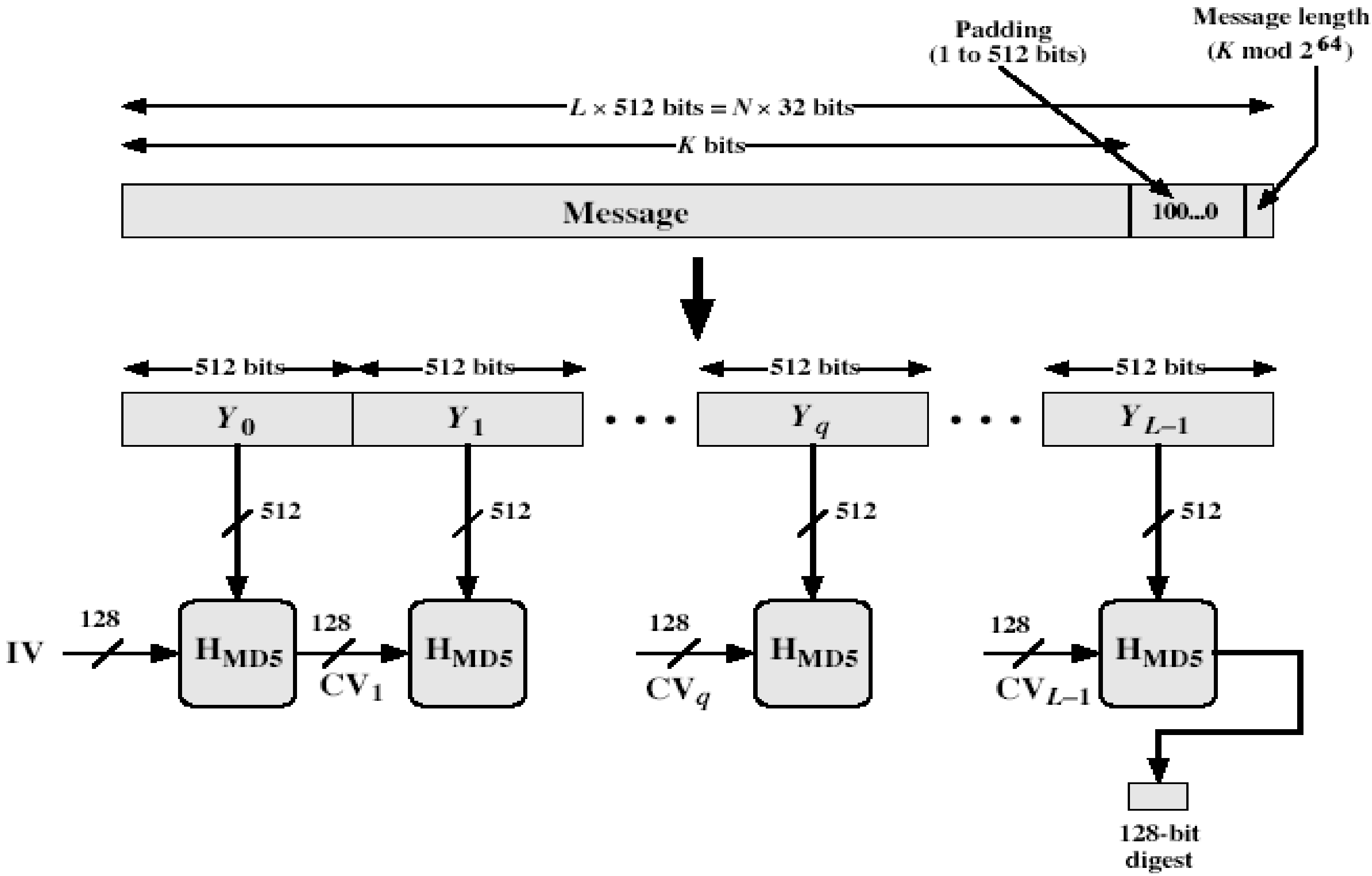


MD5 Overview

1. pad message so its length is 448 mod 512
   - Padding of 1-512 bits is always used.
   - Padding: 1000….0
2. append a 64-bit length value to message
   - Generate a message with 512L bits in length
3. initialise 4-word (128-bit) MD buffer (A,B,C,D)
4. process message in 16-word (512-bit) blocks:
5. output hash value is the final buffer value



MD5 Overview



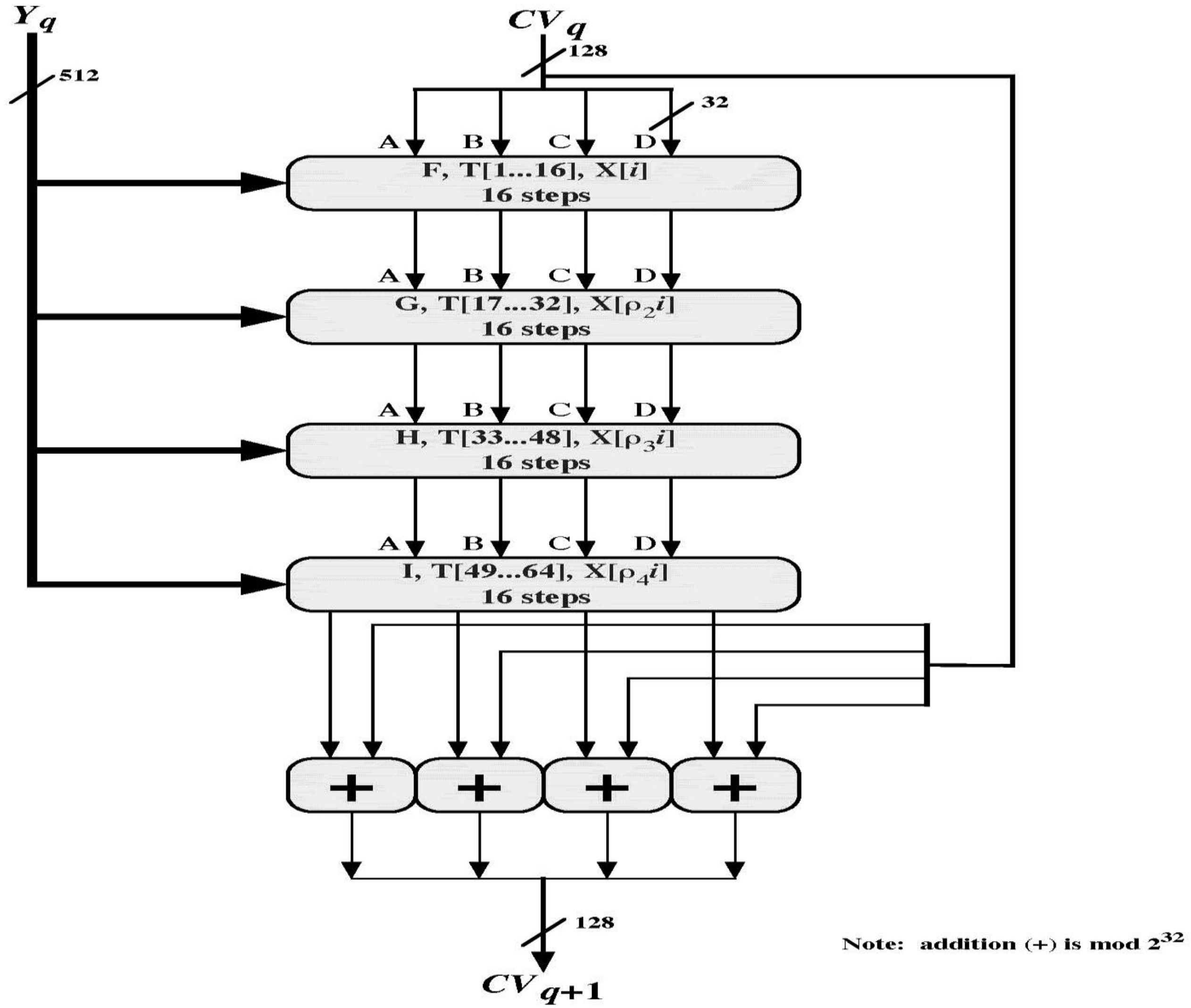


Figure 12.2 MD5 Processing of a Single 512-bit Block

MD5 Algorithm

- For 32-bit words A,B,C, define

  $F(A,B,C) = (A \wedge B) \vee (\neg A \wedge C)$

  $G(A,B,C) = (A \wedge C) \vee (B \wedge \neg C)$

  $H(A,B,C) = A \oplus B \oplus C$

  $I(A,B,C) = B \oplus (A \vee \neg C)$
- Where $\wedge$, $\vee$, $\neg$, $\oplus$ are AND, OR, NOT, XOR, respectively
- Note that G "less symmetric" than in MD4

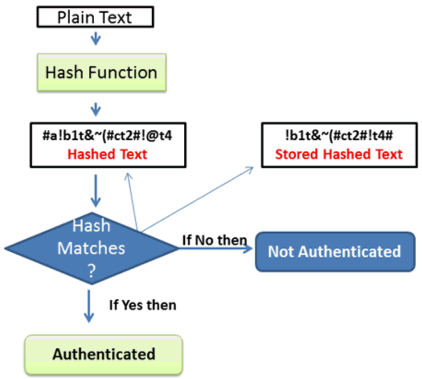
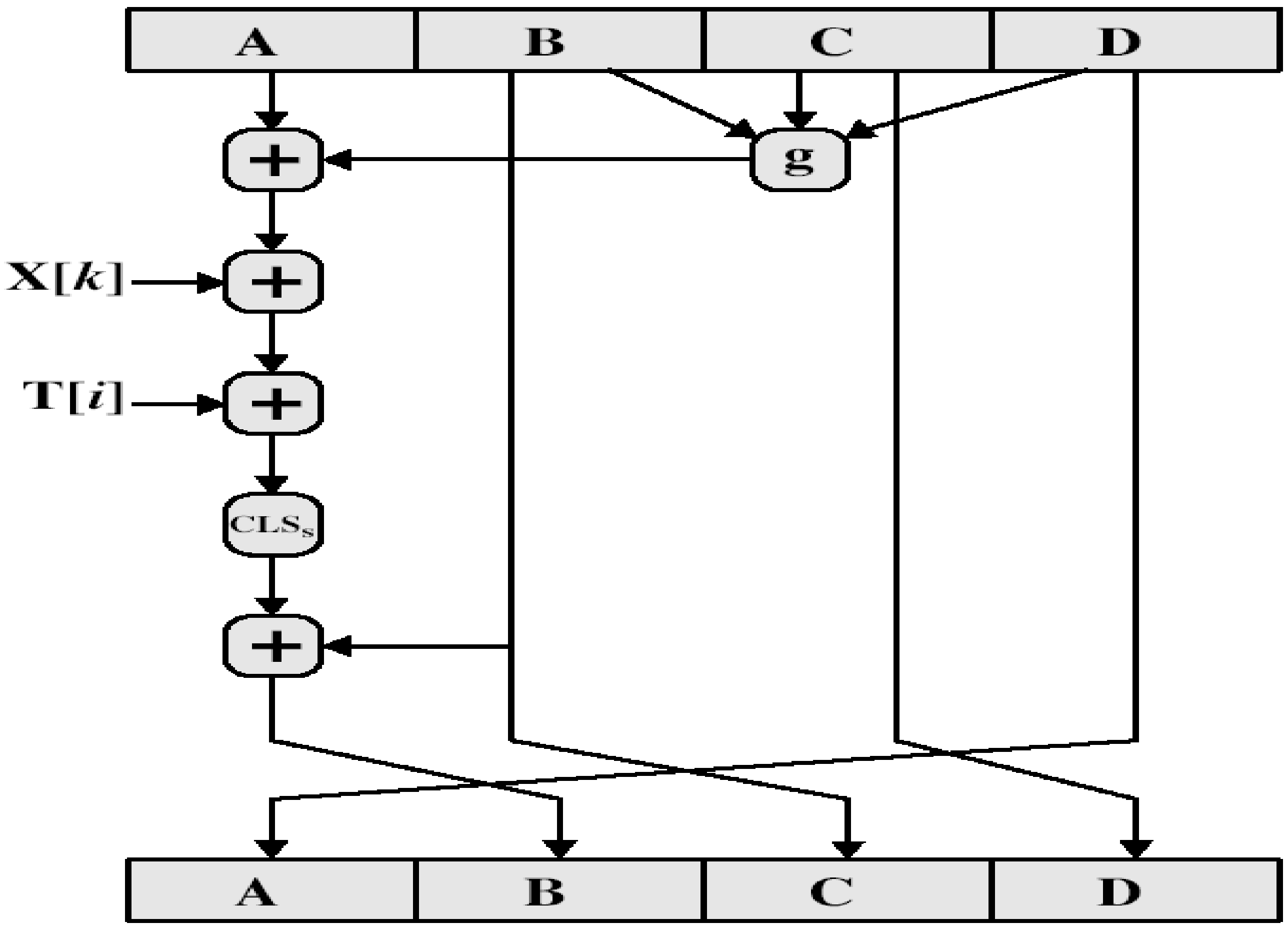


Fig : Flow Chart Example of Hash work

MD5 Compression Function



MD5 Compression Function

- each round has 16 steps of the form:

  `a = b+((a+g(b,c,d)+X[k]+T[i])<<<s)`

  `<<< denotes left bit rotation by s places`

- a,b,c,d refer to the 4 words of the buffer, but used in varying permutations
  - note this updates 1 word only of the buffer
  - after 16 steps each word is updated 4 times
- where g(b,c,d) is a different nonlinear function in each round (F,G,H,I)
- T[i] is a constant value derived from sin
- The point of all this complexity:
  - To make it difficult to generate collisions

Strength of MD5

- Every hash bit is dependent on all message bits
- Rivest conjectures security is as good as possible for a 128 bit hash
  - Given a hash, find a message: $O(2^{128})$ operations
  - No disproof exists yet
- known attacks are:
  - Berson 92 attacked any 1 round using differential cryptanalysis (but can't extend)
  - Boer & Bosselaers 93 found a pseudo collision (again unable to extend)
  - Dobbertin 96 created collisions on MD compression function for one block, cannot expand to many blocks
  - Brute-force search now considered possible

Applications of MD5

MD5 hash Properties (one-way encrypting, fixed length output, speed of generation, etc.) make it useful for many tasks.

- Often used to generate a checksum of whole files (especially apparent in the open source world)
- The developer of the application often runs the downloadable tarball through MD5 and then publishes the message digest.
- When the user downloads the application, they can also generate the MD5 hash of the tarball they downloaded. If the developer's MD5 matches the one the user has generated, then the two applications are the same. If they don't match, then the two applications are different, which means the downloaded version could contain a virus or the like.

MD5 versus SHA-1

- Comparing MD5 and SHA

Criteria	MD5	SHA-1
Key Length	128 Bit	160 Bit
Maximum size of data	infinite	2^64 Bits
Main advantage	Speed	Security

Meaning of Names: Message Digest 5, Secure Hash Algorithm -1

SHA-1 verses MD5

- brute force attack is harder (160 vs 128 bits for MD5)
- not vulnerable to any known attacks (compared to MD4/5)
- a little slower than MD5 (80 vs 64 steps)
- both designed as simple and compact
- optimised for big endian CPU's (SUN) vs MD5 for little endian CPU's (PC)

MD5 now considered insecure

- In December of 2008, researchers described a successful attack on the MD5 algorithm using 200 PlayStation 3 systems. They were able to construct a bogus Certificate Authority that looks like a known trusted CA. What this means is that they could generate a certificate for www.amazon.com which your browser would accept as the real thing. The digital signature on the fake certificate is listed as coming from a supposedly reputable CA, so the browser happily accepts it, reassuringly showing you the little padlock icon.

- **Source: http://www.crunchgear.com/2008/12/30/md5-collision-creates-rogue-certificate-authority/**

Brute Force Cracking

- Going through many combinations of characters until the message digest outputted by one of them equals the message digest that you are trying to match.
- Many homes now have CPUs that would have been considered supercomputers a few years ago, such as the Sony PlayStation 3. A successful attack on MD-5 used 200 PS3 consoles.
- MD5 hashes are designed to be unique. The chances that two different inputs would have the same message digest is very small (1/(16^32) or about 1/(3.4E+38)), but possible.
- MD5 has been compromised, and SHA-1 (Secure Hash Algorithm 1) is now more widely used.

Secure Hash Algorithm (SHA-1)

- SHA was designed by NIST & NSA in 1993, revised 1995 as SHA-1
- US standard for use with DSA signature scheme
  - standard is FIPS 180-1 1995, also Internet RFC3174
  - nb. the algorithm is SHA, the standard is SHS
- produces 160-bit hash values
- now the generally preferred hash algorithm
- based on design of MD4 with key differences

SHA Overview

1. pad message so its length is 448 mod 512
2. append a 64-bit length value to message
3. initialise 5-word (160-bit) buffer (A,B,C,D,E) to (67452301,efcdab89,98badcfe,10325476,c3d2e1f0)
4. process message in 16-word (512-bit) chunks:
   - expand 16 words into 80 words by mixing & shifting
   - use 4 rounds of 20 bit operations on message block & buffer
   - add output to input to form new buffer value
5. output hash value is the final buffer value

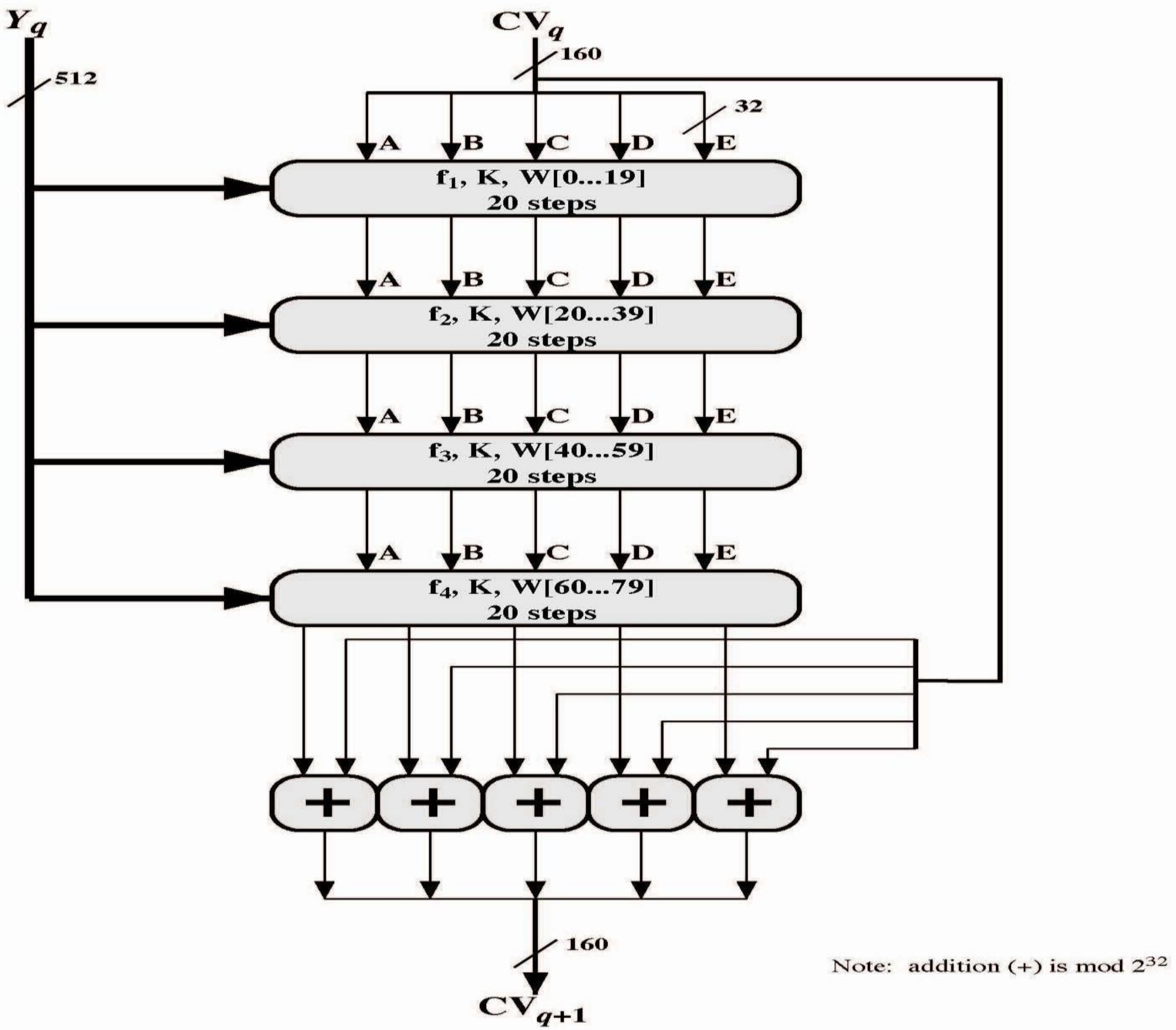
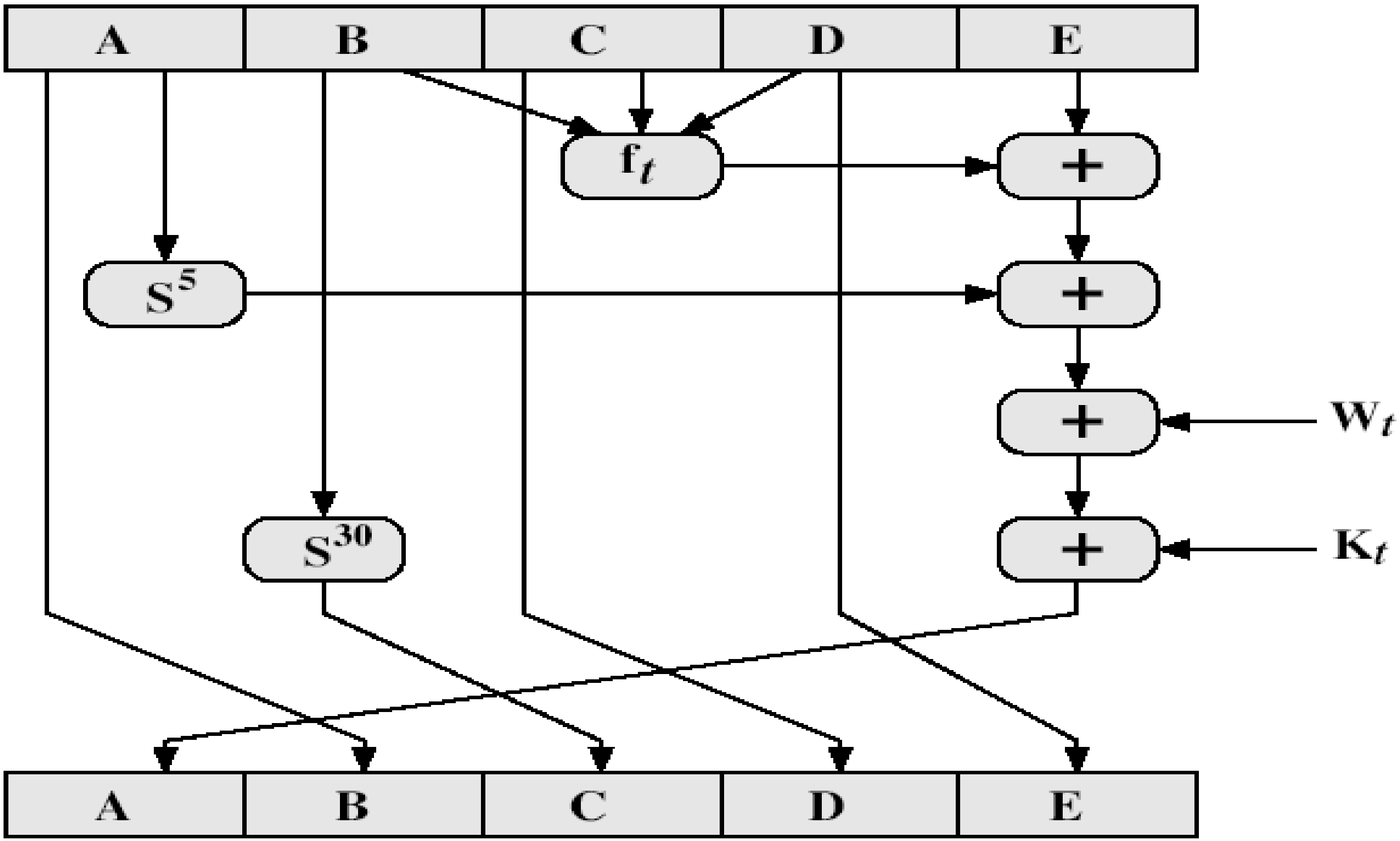


Figure 12.5 SHA-1 Processing of a Single 512-bit Block (SHA-1 Compression Function)

SHA-1 Compression Function



Logical functions for SHA-1

Table 12.2 Truth Table of Logical Functions for SHA-1

B	C	D	$f_{0..19}$	$f_{20..39}$	$f_{40..59}$	$f_{60..79}$
0	0	0	0	0	0	0
0	0	1	1	1	0	1
0	1	0	0	1	0	1
0	1	1	1	0	1	0
1	0	0	0	1	0	1
1	0	1	0	0	1	0
1	1	0	1	0	1	0
1	1	1	1	1	1	1

SHA-1 Compression Function

- each round has 20 steps which replaces the 5 buffer words thus:

  `(A,B,C,D,E) <-`
  `(E+f(t,B,C,D)+(A<<5)+`W_t`+`K_t`),A,(B<<30),C,D)`

- ABCDE refer to the 5 words of the buffer
- t is the step number
- `f(t,B,C,D)` is nonlinear function for round
- W_t is derived from the message block
- K_t is a constant value (P359)

Creation of 80-word input

- Adds redundancy and interdependence among message blocks

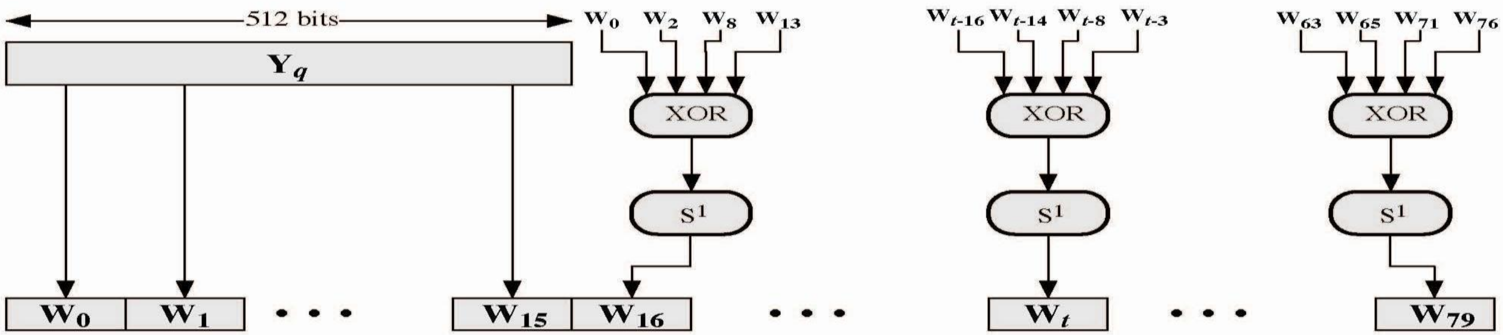


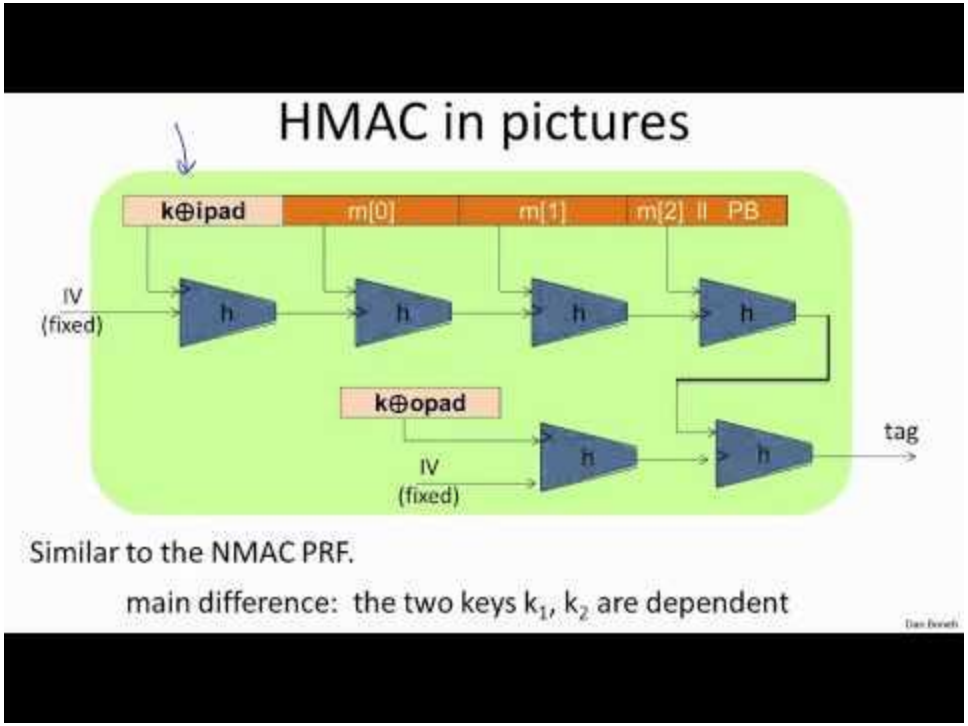
Figure 12.7 Creation of 80-word Input Sequence for SHA-1 Processing of Single Block

Table 12.3 Comparison of SHA Properties

	SHA-1	SHA-256	SHA-384	SHA-512
Message digest size	160	256	384	512
Message size	$< 2^{64}$	$< 2^{64}$	$< 2^{128}$	$< 2^{128}$
Block size	512	512	1024	1024
Word size	32	32	64	64
Number of steps	80	80	80	80
Security	80	128	192	256

Notes: 1. All sizes are measured in bits.
2. Security refers to the fact that a birthday attack on a message digest of size n produces a collision with a workfactor of approximately $2^{n/2}$.

HMAC


HMAC in pictures
k⊕ipad
m[0]
m[1]
m[2] ll PB
IV
(fixed)
h
k⊕opad
IV
(fixed)
tag
Similar to the NMAC PRF.
main difference: the two keys k_1, k_2 are dependent

What is more secure?

- Longer messages lead to more collision per hash value
  - Is it more secure to use shorter messages?
  - Need to consider the scenarios
    - Known message, find out a collision message
    - Find out a collision pair using birthday attack
- Uniform distribution assumption

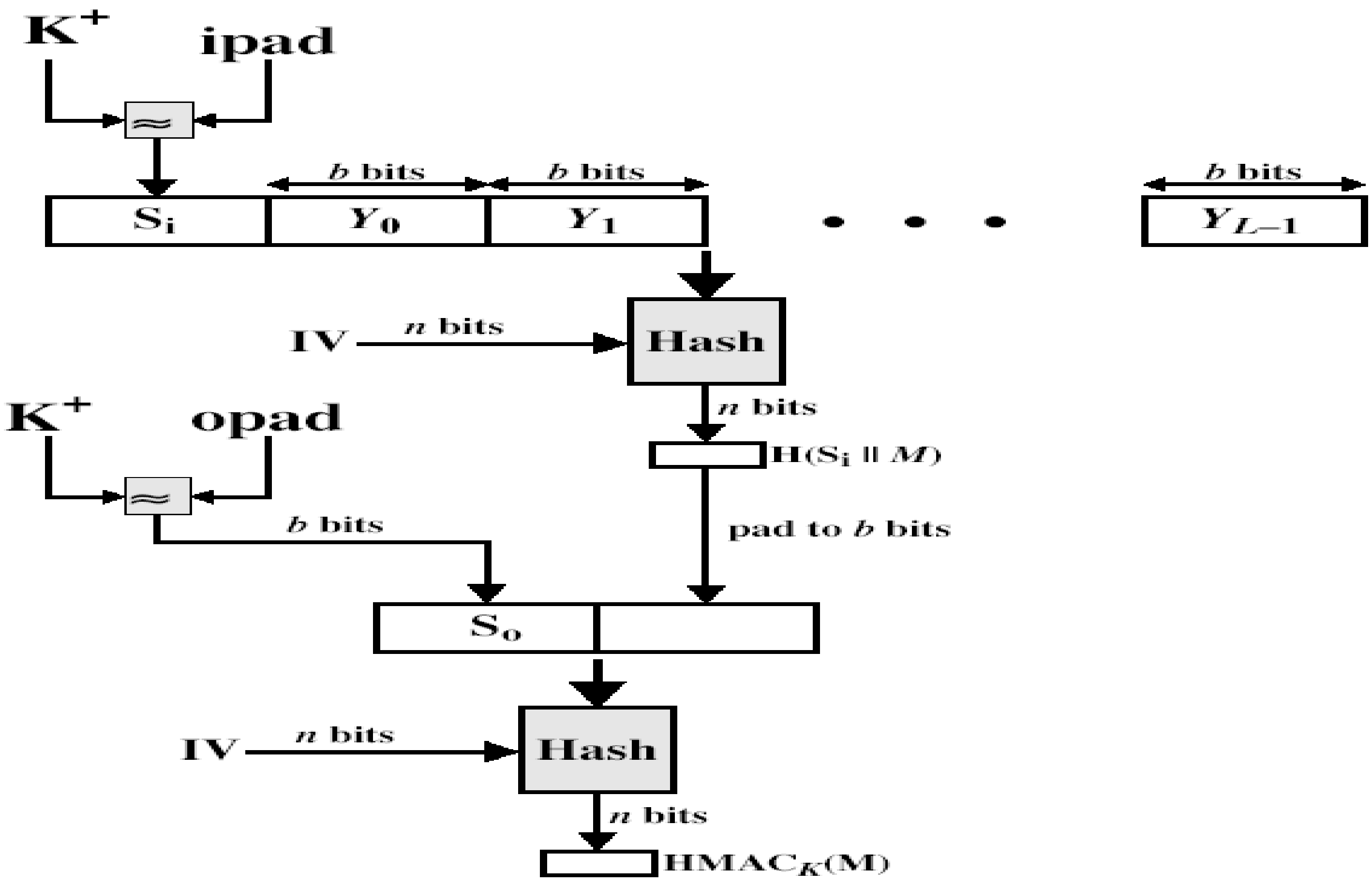
Keyed Hash Functions as MACs

- have desire to create a MAC using a hash function rather than a block cipher
  - because hash functions are generally faster
  - not limited by export controls unlike block ciphers
- hash includes a key along with the message
- led to development of HMAC

HMAC Requirements

- Blackbox use of hash without modification
- Not much overhead than original hash
- Easy to replace the hash module
  - Easy to upgrade security

HMAC Overview



HMAC

- specified as Internet standard RFC2104
- uses hash function on the message:

$$\mathrm{HMAC}_K = \mathrm{Hash}[(K^+ \text{ XOR opad}) \,||\, \mathrm{Hash}[(K^+ \text{ XOR ipad}) || M)]]$$

- where K^+ is the key padded out to size
- and opad, ipad are specified padding constants
- overhead is just 3 more hash calculations than the message needs alone
- any of MD5, SHA-1, RIPEMD-160 can be used

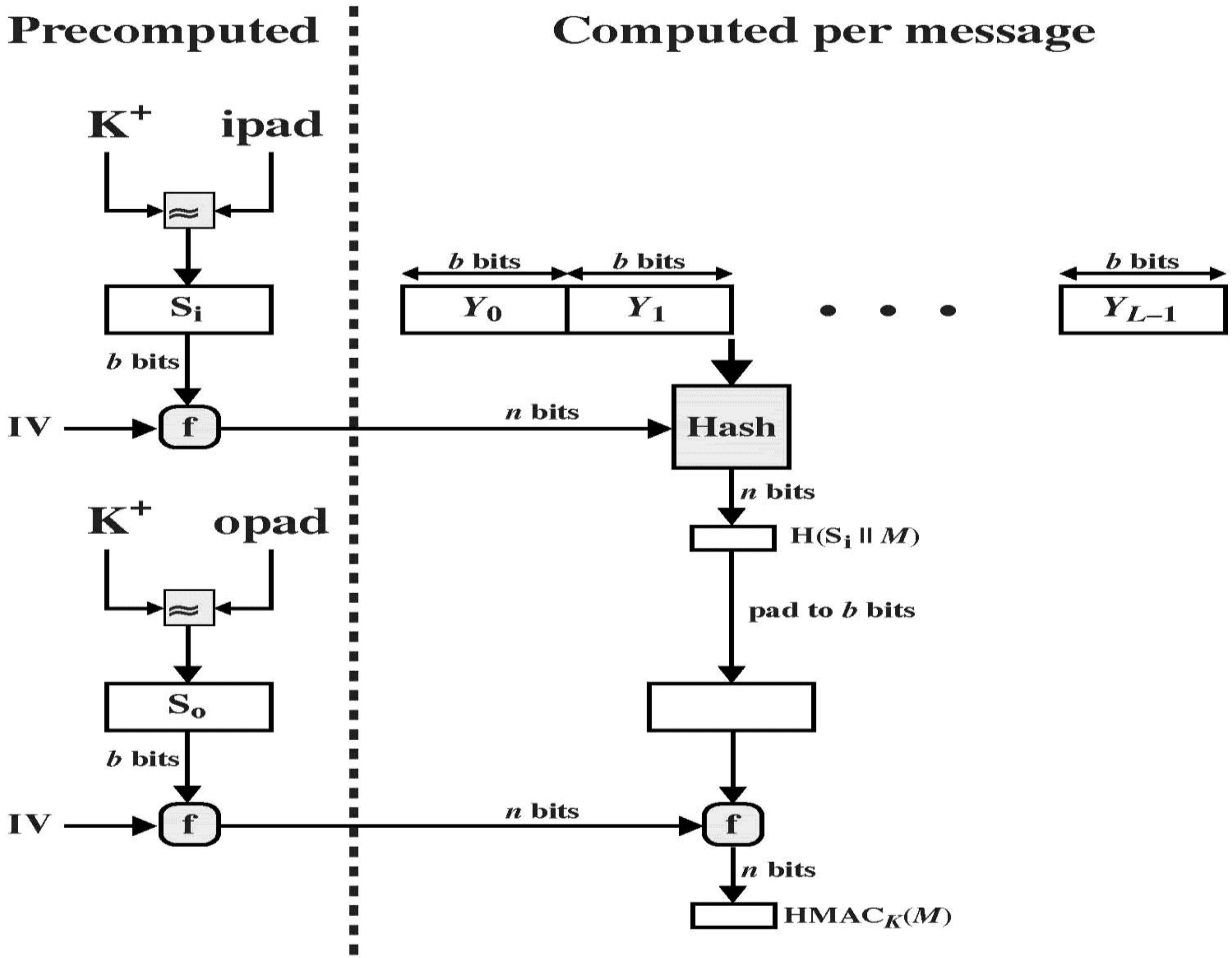


Figure 12.11 Efficient Implementation of HMAC

Summary

- have considered:
  - some current hash algorithms:
    - MD5 and SHA-1
    - HMAC authentication using a hash function

Further Inquiries

Thank You